

CARTILHA COBIT 2019



Brasília
2021

Editores

João Souza Neto

Leandro Pfeifer Macedo

Autores

Diana Leite Nunes dos Santos

Fernando César Campos Andrade, CISA, CISM, CGEIT, TOGAF, COBIT5F, ITIL

Frederico Pinto de Souza, CISA

João Souza Neto, CRISC, CGEIT, CDPSE, COBIT 2019 Design & Implementation, COBIT 2019 Approved Trainer

Leandro Pfeifer Macedo, CRISC, ITIL, CBPP, KMP, MCSO, DPO, ISO27001AL

Lidiane de Andrade Parisi, ITIL® 4 Managing Professional

Lívia Nojoza Amorim, M. Sc.

Luiz Eduardo Alves Ferreira, CISA, ICSS

Marcelo Gaspar Rodrigues Silva, CISA, CGEIT, ITIL® 4 Managing Professional, Digital Transformation Expert by DTWI®

Rhandsaissem Tavares Leal CISM, CISSP

Sandro Ricardo Nogueira Buarque e Silva, Cobit 5 Assessor Certificate, ITIL®4, Exin ASM

Sylas Rodrigues Mendes, MÓDULO SECURITY OFFICER, BS7799-2005.

Dados Internacionais de Catalogação na Publicação (CIP)
(Câmara Brasileira do Livro, SP, Brasil)

Cartilha COBIT 2019 [livro eletrônico] / João
Souza Neto, Leandro Pfeifer Macedo editores. --
Brasília : Joao Souza Neto, 2021.

PDF

Vários autores.

ISBN 978-65-00-32356-6

1. Administração 2. Framework (Programa de
computador) 3. Gestão 4. Governança corporativa
5. Tecnologia da informação I. Souza Neto, João.
II. Macedo, Leandro Pfeifer.

21-85300

CDD-658.472

Índices para catálogo sistemático:

1. Gerenciamento de recursos de informação :
Administração 658.472

Maria Alice Ferreira - Bibliotecária - CRB-8/7964

Sumário

Capítulo 1 – Introdução.....	5
Governança Corporativa da Informação e Tecnologia.....	5
Benefícios da Governança da Informação e Tecnologia	5
COBIT® como uma estrutura de governança de I&T.....	7
O que é e o que não é o COBIT®?.....	7
Capítulo 2 – Princípios COBIT® 2019	9
Introdução	9
Princípios para um Sistema de Governança.....	9
Princípios para uma estrutura de Governança	9
COBIT® 2019.....	10
Capítulo 3 – Conceitos Básicos: Sistema de Governança e Componentes	11
Visão Geral do COBIT®	11
Objetivos de Governança e Gestão.....	11
Componentes do Sistema de Governança	12
Áreas de Foco.....	13
Fatores do Desenho	13
Capítulo 4 – Objetivos de Governança e Gestão.....	16
Capítulo 5 – Gerenciamento de Desempenho no COBIT®	20
Princípios do CPM	20
Visão Geral do Gerenciamento de Desempenho no COBIT®	20
Níveis de Capacidade de Processos.....	20
Níveis de Maturidade de Áreas de Foco	21
Capítulo 6 – Desenhar um Sistema de Governança sob Medida	23
Impacto dos Fatores de Desenho.....	23
Estágios no Processo de Desenho	24
Capítulo 7 – Implementação da Governança Corporativa de TI	25
Propósito do Guia de Implementação	25
Abordagem de implementação do COBIT®	25

Capítulo 1 – Introdução

Governança Corporativa da Informação e Tecnologia

À luz da transformação digital, a informação e tecnologia (I&T) tornaram-se cruciais no suporte, sustentabilidade e crescimento das organizações. Anteriormente, a alta administração poderia delegar, ignorar ou evitar decisões relacionadas à I&T. Na maioria dos setores e indústrias, tais atitudes agora não são aceitas.

A criação de valor para as partes interessadas (ou seja, perceber os benefícios com custo e riscos otimizados) é, muitas vezes, impulsionada por um alto grau de digitalização em novos modelos de negócios, processos eficientes, sucesso na inovação etc. As organizações digitais estão cada vez mais dependentes da I&T para sua sobrevivência e crescimento.

A governança corporativa da informação e tecnologia (GCIT) surgiu nas últimas três décadas e é parte integral da governança corporativa. Ela é exercida pela diretoria e esta supervisiona a definição e implementação de processos, estruturas e mecanismos relacionais na organização os quais permitem que os negócios e o pessoal de TI executem suas responsabilidades no apoio ao alinhamento negócios/TI e na criação de valor de negócios a partir do uso de I&T, como mostrado na figura 1.



Figura 1 - Contexto da GCIT. Adaptado de COBIT 2019 Introduction and Methodology

A governança corporativa de informação e tecnologia é complexa e multifacetada. Não há forma ideal para projetar, implementar e manter uma GCIT eficaz dentro de uma organização. Como tal, o conselho de administração e a gestão executiva, normalmente, precisam adaptar os modelos de GCIT aos seus próprios contextos e necessidades. Eles também devem estar dispostos a aceitar mais responsabilidade por I&T e conduzir uma mentalidade e cultura para agregar valor de I&T.

Benefícios da Governança da Informação e Tecnologia

Fundamentalmente, a GCIT está preocupada com a entrega de valor da transformação digital e com a mitigação dos riscos de negócios que resultam da transformação digital. Mais especificamente, três resultados principais podem ser esperados após o sucesso na adoção da GCIT:

Realização de benefícios - Consiste em criar valor para a organização por meio de I&T, ao manter e aumentar o valor derivado de investimentos de I&T e eliminar iniciativas e ativos de TI que não criam valor suficiente. O princípio básico do valor de I&T é a entrega, dentro do prazo e dentro do orçamento, de serviços e soluções adequados às suas finalidades, e que geram os benefícios financeiros e não financeiros pretendidos. O valor que a I&T oferece deve estar alinhado diretamente com os valores nos quais o negócio está focado. O valor da TI também deve ser medido de uma forma que mostre o impacto

e as contribuições dos investimentos habilitados pela TI no processo de criação de valor das iniciativas.

Otimização de risco – Este benefício envolve a abordagem do risco de negócios associado ao uso, propriedade, operação, envolvimento, influência e adoção de I&T dentro de uma organização. O risco de negócios relacionado à I&T consiste em eventos de I&T que podem impactar potencialmente os negócios. Embora a entrega de valor se concentre na criação de valor, a gestão de riscos concentra-se na preservação de valor. A gestão de riscos relacionados à I&T deve ser integrada à abordagem de gestão de risco corporativa para garantir o foco na I&T por parte da organização. Também deve ser medida de uma forma que mostre o impacto e as contribuições da otimização de riscos de negócios relacionados à I&T na preservação de valor.

Otimização de recursos - Este benefício garante que os recursos apropriados, suficientes e eficazes estejam disponíveis para executar o plano estratégico. A otimização de recursos garante que um ambiente integrado, uma infraestrutura de TI econômica e novas tecnologias sejam introduzidos conforme exigido pelos negócios e os sistemas obsoletos sejam atualizados ou substituídos. Por reconhecer a importância das pessoas, além do hardware e software, a otimização de recursos concentra-se em fornecer treinamento, promover a retenção e garantir a competência do pessoal-chave da TI. Os recursos importantes são os dados e as informações, e a exploração desses dados e informações para a obtenção do valor ideal é outro elemento-chave da otimização de recursos.

A figura 2 ilustra os benefícios da GCIT.



Figura 2 - Contexto da GCIT. Adaptado de COBIT 2019 Introduction and Methodology

O Alinhamento Estratégico e a Medição de Desempenho são de suma importância e, em geral, eles se aplicam a todas as atividades para garantir que os objetivos relacionados à I&T estejam alinhados com as metas da organização.

Em um grande estudo de caso de uma companhia aérea internacional, os benefícios da GCIT demonstraram o seguinte: menores custos de continuidade relacionados à TI, maior capacidade de inovação habilitada pela TI, maior alinhamento entre investimentos digitais e a estratégia de negócios, uma maior confiança entre negócios e TI, e uma mudança em direção a uma "mentalidade de valor" em torno de ativos digitais. A pesquisa demonstrou que as organizações que apresentam abordagens mal projetadas ou mal adotadas para GCIT mostram pior desempenho no alinhamento entre estratégias e processos de negócios e I&T. Como resultado, essas organizações são muito menos propensas a alcançar suas pretendidas estratégias de negócios e perceber o valor de negócio que esperam da transformação digital.

COBIT® como uma estrutura de governança de I&T

Ao longo dos anos, foram desenvolvidas e promovidas estruturas de melhores práticas para auxiliar no processo de compreensão, concepção e implementação de GCIT. Há mais de 25 anos, o COBIT® integra o desenvolvimento neste campo, não apenas pela incorporação de novas visões da ciência, mas, também, ao operacionalizar essas visões como práticas.

Desde sua fundação na comunidade de auditoria de TI, o COBIT® se desenvolveu em uma estrutura de governança e gestão de I&T mais ampla e abrangente e continua estabelecida como uma estrutura geralmente aceita para governança de I&T.

O que é e o que não é o COBIT®?

Antes de descrever a estrutura COBIT® atualizada, é importante explicar o que o COBIT® é e o que não é.

O COBIT® é uma estrutura para a governança e gestão da informação e tecnologia organizacional, dirigida a toda a organização. I&T corporativa significa toda a tecnologia e processamento de informações que a organização utiliza para atingir seus objetivos, independentemente de onde isso aconteça na organização. Em outras palavras, a I&T corporativa não se limita à área de TI de uma organização.

A estrutura do COBIT® faz uma distinção clara entre governança e gestão. Essas duas disciplinas abrangem atividades diferentes, requerem estruturas organizacionais diferentes e servem a propósitos diferentes.

- A governança garante que:

- As necessidades, condições e opções das partes interessadas sejam avaliadas para determinar objetivos organizacionais equilibrados e acordados;
- A direção é definida por meio de priorização e tomada de decisões; e
- O desempenho e a conformidade são monitorados em relação à direção e aos objetivos acordados.

Na maioria das organizações, a governança corporativa é responsabilidade do conselho de administração. Algumas responsabilidades específicas de governança podem ser delegadas a estruturas organizacionais especiais em um nível apropriado, especialmente em organizações maiores e complexas.

- A gestão, por seu lado, planeja, constrói, executa e monitora as atividades em alinhamento com a direção definida pela governança corporativa, para atingir os objetivos organizacionais.

- Na maioria das organizações, a gestão é responsabilidade da gestão executiva, sob a liderança do presidente.

O COBIT® define os componentes para construir e sustentar um sistema de governança tais como processos, estruturas organizacionais, políticas e procedimentos, fluxos de informação, cultura e comportamentos, habilidades e infraestrutura.

O COBIT® estabelece os fatores de desenho que devem ser considerados pela organização para construir um sistema de governança mais adequado.

O COBIT® aborda questões de governança ao agrupar componentes de governança relevantes em objetivos de governança e gestão que podem ser gerenciados para os níveis de capacidade exigidos.

Vários equívocos sobre o COBIT® devem ser dissipados:

- O COBIT® não é uma descrição completa de todo o ambiente de TI de uma organização;
- O COBIT® não é uma estrutura para organizar processos de negócios;
- O COBIT® não é uma estrutura técnica de TI para gerenciar toda a tecnologia;
- O COBIT® não toma nem prescreve quaisquer decisões relacionadas à TI.

Não decide qual é a melhor estratégia de TI, qual é a melhor arquitetura ou quanto a TI pode ou deve custar. Em vez disso, o COBIT® define todos os componentes que descrevem quais decisões devem ser tomadas, como e por quem elas devem ser tomadas.

Introdução

O COBIT® 2019 foi desenvolvido com base em dois conjuntos de princípios:

- Princípios que descrevem os principais requisitos de um Sistema de Governança para informações e tecnologia; e
- Princípios para uma estrutura de Governança que pode ser utilizada para construir um Sistema de Governança para a toda a organização.

Princípios para um Sistema de Governança

Os seis princípios para um Sistema de Governança são (figura 3):

1. Cada organização precisa de um Sistema de Governança para satisfazer as necessidades das partes interessadas e gerar valor a partir do uso da TI. O valor reflete um equilíbrio entre benefícios, riscos e recursos, e as organizações precisam de uma estratégia que possa ser acionada e um sistema de governança para realizar esse valor;
2. Um Sistema de Governança Corporativa de TI é construído a partir de uma série de componentes que podem ser de diferentes tipos e que trabalham juntos de uma forma holística;
3. Um Sistema de Governança deve ser dinâmico. Isso significa que cada vez que um ou mais dos fatores de desenho são alterados (por exemplo, uma mudança de estratégia ou tecnologia), o impacto dessas mudanças no Sistema de Governança Corporativa de TI deve ser considerado. Uma visão dinâmica da governança Corporativa de TI levará a um Sistema de Governança Corporativa de TI viável e com prontidão estratégica;
4. Um Sistema de Governança deve distinguir claramente entre as atividades e estruturas de Governança e Gestão;
5. Um Sistema de Governança deve ser adaptado às necessidades da organização, com a utilização de um conjunto de fatores de desenho como parâmetros para personalizar e priorizar os componentes do Sistema de Governança; e
6. Um Sistema de Governança deve cobrir a organização de ponta a ponta, focando não apenas na função de TI, mas em toda a tecnologia e processamento de informações que a organização coloca em prática para alcançar seus objetivos, independentemente de onde o processamento está localizado na organização.



Figura 3 - Seis princípios de um Sistema de Governança. Adaptado de COBIT 2019 Introduction and Methodology

Princípios para uma estrutura de Governança

São três os princípios para uma estrutura de Governança (figura 4):

1. Principais componentes e relacionamentos entre eles, para maximizar a consistência e permitir a automação;

2. Uma estrutura de Governança deve ser aberta e flexível. Deve permitir a inclusão de novos conteúdos e ter capacidade para abordar novos problemas da maneira mais flexível possível, mantendo a integridade e consistência.
3. Uma estrutura de Governança deve estar alinhada com os principais padrões, estruturas e regulamentos relevantes.



Figura 4 - Princípios da estrutura de Governança. Adaptado de COBIT 2019 Introduction and Methodology

COBIT® 2019

Em relação às versões anteriores do COBIT®, o COBIT® 2019 é melhor nas seguintes áreas:

- Flexibilidade e abertura - A definição e o uso de fatores de desenho permitem que o COBIT® 2019 seja adaptado para um melhor alinhamento com o contexto particular de uma organização. A arquitetura aberta do COBIT® 2019 permite adicionar novas áreas de foco ou modificar as existentes, sem implicações diretas na estrutura e no conteúdo do modelo central do COBIT®;
- Atual e relevante - O modelo COBIT® oferece suporte a referências e alinhamento a conceitos originados em outras fontes (por exemplo, os mais recentes padrões de TI e regulamentações de conformidade);
- Aplicação prescritiva - Modelos como o COBIT® podem ser descritivos e prescritivos. O COBIT®, como um modelo conceitual, é construído de modo que sua instanciação seja percebida como um mecanismo para um sistema de governança de TI feito sob medida;
- Gestão de desempenho de TI - A estrutura do modelo de Gestão de Desempenho COBIT® está integrada em um modelo conceitual. Os conceitos de maturidade e capacidade são introduzidos para um melhor alinhamento com o CMMI.

O COBIT® usa os termos Governança de Tecnologia e Informação Corporativa, Governança Corporativa de Informação e Tecnologia e Governança de TI de forma intercambiável.

Capítulo 3 – Conceitos Básicos: Sistema de Governança e Componentes

Visão Geral do COBIT®

A família de produtos do COBIT® é um conjunto em aberto, projetado para ser customizado. As seguintes publicações estão atualmente disponíveis:

- Estrutura do COBIT® 2019: Introdução e Metodologia, apresenta os conceitos-chave do COBIT®;
- Estrutura do COBIT® 2019: Objetivos de Governança e de Gestão, descreve, de forma completa, os 40 objetivos de governança e gestão, os processos ali contidos e outros componentes relacionados. O guia também faz referência a outros padrões e estruturas;
- Guia de Planejamento do COBIT® 2019: Projetar uma Solução de Governança de Informação e Tecnologia. O guia explora os fatores envolvidos nos projetos que podem influenciar a governança, incluindo um fluxo para planejar um sistema de governança adaptado à organização;
- Guia de Implementação do COBIT® 2019: Implementar e Otimizar uma Solução de Governança de Informação e Tecnologia. Este guia representa uma evolução do Guia de Implementação do COBIT® 5 e desenvolve um roteiro para a melhoria contínua da governança. Pode ser utilizado em conjunto com o Guia de Planejamento do COBIT® 2019.

Objetivos de Governança e Gestão

Para que a informação e tecnologia contribuam com os objetivos do negócio, alguns objetivos de governança e gestão devem ser alcançados. Os conceitos básicos relacionados a objetivos de governança e gestão são:

- Um objetivo de governança ou de gestão sempre está relacionado a um processo (com um nome idêntico ou parecido) e uma série de componentes de outros tipos para auxiliar no alcance do objetivo;
- Um objetivo de governança está relacionado a um processo de governança, enquanto um objetivo de gestão está relacionado a um processo de gestão.

Conselhos e diretorias são responsáveis pelos processos de governança, enquanto os processos de gestão são de domínio da alta e da média gerência.

Os objetivos de governança e gestão no COBIT® estão agrupados em cinco domínios, conforme a figura 5. Os domínios são denominados por verbos que expressam o propósito-chave e as áreas de atividade dos objetivos neles contidos.

Os objetivos de governança estão agrupados no domínio Avaliar, Dirigir e Monitorar (EDM – *Evaluate, Direct, and Monitor*). Neste domínio, os órgãos de governança avaliam as opções estratégicas, direcionam o corpo gerencial na execução das opções estratégicas e monitoram o cumprimento da estratégia.

Os objetivos de gestão estão agrupados em quatro domínios:

- Alinhar, Planejar e Organizar (APO – *Align, Plan, and Organize*). Este domínio aborda a organização em geral, a estratégia e as atividades de gestão da TI.
- Construir, Adquirir e Implementar (BAI – *Build, Acquire, and Implement*). Este domínio aborda a definição, aquisição e implementação de soluções de TI e suas integrações nos processos de negócio.

- Entregar, Prestar Serviços e dar Suporte (DSS – *Deliver, Service, and Support*). Este domínio tem foco na prestação e suporte dos serviços de TI, inclusive de serviços de segurança.
- Monitorar, Avaliar e Analisar (MEA – *Monitor, Evaluate, and Assess*). Este domínio tem objetivos com foco no monitoramento do desempenho e na conformidade da TI com os objetivos de controles internos e os requisitos externos.

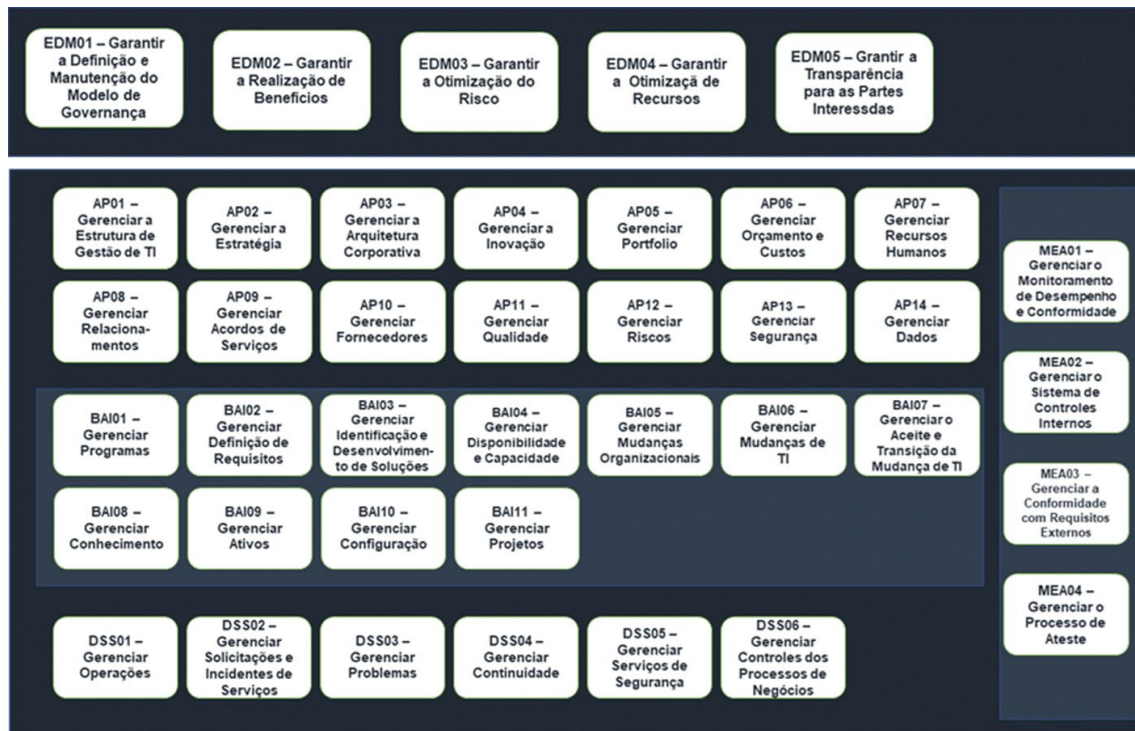


Figura 5 - Modelo Central do COBIT. Adaptado de COBIT 2019 Introduction and Methodology

Componentes do Sistema de Governança

Para atender os objetivos de governança e de gestão, cada organização precisa estabelecer, customizar e sustentar um sistema de governança, composto por vários componentes

Componentes são fatores que, isoladamente ou em conjunto, contribuem para a boa operação do sistema de governança de TI da organização. Eles interagem entre si, resultando em um sistema holístico de governança para a TI.

Os componentes podem ser de tipos diferentes, sendo o mais familiar o componente processos. No entanto, os componentes de um sistema de governança também incluem estruturas organizacionais, políticas e normas, itens de informação, cultura e comportamento, habilidades e competências, assim como serviços, infraestrutura e aplicativos (figura 6).

- Processos descrevem um conjunto organizado de práticas e atividades para alcançar alguns objetivos, resultando em produtos que darão suporte ao atingimento dos objetivos gerais relacionados à TI.
- Estruturas Organizacionais são entidades-chave no processo decisório em uma organização.

- Princípios, políticas e procedimentos traduzem o comportamento esperado em guias práticos para a gestão do dia a dia.
- Informação inclui todas as informações produzidas e utilizadas pela organização. O COBIT® concentra seu foco nas informações necessárias para o efetivo funcionamento do sistema de governança de I&T.
- Cultura, ética e comportamento dos indivíduos e da organização são, frequentemente, fatores subestimados para o sucesso das atividades de governança e gestão.
- Pessoas, habilidades e competências são requisitos para boas decisões, execução de ações corretivas e a conclusão bem-sucedida de todas as atividades.



Figura 6 - Componentes de um Sistema de Governança. Adaptado de COBIT 2019 Introduction and Methodology

Áreas de Foco

Uma área de foco descreve um determinado tópico de governança, domínio ou assunto que pode ser trabalhado por um conjunto de objetivos de gestão e governança e seus componentes. Exemplos de áreas de foco incluem pequenas e médias organizações, segurança cibernética, transformação digital, computação em nuvem, privacidade e DevOps. Áreas de foco podem conter uma combinação de componentes genéricos de governança e suas variantes.

A quantidade de áreas de foco é virtualmente ilimitada. Isto é o que faz o COBIT® aberto e dinâmico. Novas áreas de foco podem ser acrescentadas quando necessário ou quando especialistas ou profissionais de um determinado assunto fizerem uma contribuição ao modelo aberto do COBIT®.

Fatores do Desenho

Fatores de desenho são fatores que podem influenciar o projeto do sistema de governança de uma organização e conduzi-lo com sucesso no uso estratégico de TI.

Fatores de projetos podem ser qualquer combinação dos seguintes elementos:

Estratégia Organizacional – As Organizações podem ter diferentes estratégias, as quais podem ser expressas por meio de um ou mais arquétipos: Crescimento/Aquisição, Inovação/Diferenciação, Liderança em Custo, e Serviço ao Cliente/Estabilidade. Normalmente as organizações possuem uma estratégia primária e, na maioria dos casos, uma estratégia secundária. Devem ser definidos níveis de importância (1 a 5) para cada um dos 4 arquétipos.

Objetivos Organizacionais – A estratégia organizacional é concretizada pelo alcance de (um conjunto de) objetivos organizacionais. Esses objetivos estão definidos na estrutura do COBIT®, modelados nas dimensões do *Balanced Scorecard (BSC)*. Devem ser definidos níveis de importância (1 a 5) para cada um dos 13 objetivos.

Perfil de Risco da organização – O perfil de risco consiste na avaliação da probabilidade e do impacto de cada categoria de cenário de risco. São 20 categorias de cenários de risco, cobrindo os principais tipos de risco que afetam as organizações.

Problemas relacionados à TI – Este fator permite a identificação dos pontos de dor da organização, isto é, dos problemas estratégicos e táticos crônicos. Devem ser definidos níveis de severidade (1 a 3) para cada um dos pontos de dor.

Cenário de Ameaças – O cenário de ameaças sob o qual a organização opera pode ser classificado em Alto e Normal. Devem ser definidos percentuais para cada uma das classes, observando que o total deve dar exatamente 100%.

Requisitos de Conformidade – O peso dos requisitos de conformidade aos quais a organização está sujeita podem ser classificados em Alto, Normal e Baixo. Devem ser definidos percentuais para cada uma das classes, observando que o total deve dar exatamente 100%.

Papel da TI – O papel da TI para a organização pode ser classificado como TI Suporte, TI Fábrica, TI Transformadora e TI Estratégica. Vale a pena explicar melhor cada um destes tipos: TI Suporte - A TI não é crucial para a execução e continuidade dos processos e serviços de negócios, nem para sua inovação; TI Fábrica - Quando a TI falha, há um impacto imediato na execução e continuidade dos processos de negócios e serviços. No entanto, a TI não é vista como um impulsionador para inovar processos e serviços de negócios; TI Transformadora - A IT é vista como um direcionador para inovar processos e serviços de negócios. Neste momento, no entanto, não há uma dependência crítica da TI para a execução e continuidade dos processos de negócios e serviços; e TI Estratégica - A TI estratégica é essencial para a execução e inovação dos processos e serviços de negócios da organização. Novamente, devem ser definidos percentuais para cada uma das classes, observando que o total deve dar exatamente 100%.

Modelo de Provimento de TI – O modelo de provimento de TI adotado pela organização pode ser classificado em Terceirização, Nuvem e Desenvolvimento Interno. Devem ser definidos percentuais para cada um dos modelos, observando que o total deve dar exatamente 100%.

Métodos de Implementação de TI – Os métodos que a organização adota podem ser classificados como Métodos Ágeis, DevOps e Tradicional. Devem ser definidos percentuais para cada um dos métodos, observando que o total deve dar exatamente 100%.

Estratégia de Adoção de Tecnologia – A estratégia de adoção de tecnologia pode ser classificada Como Pioneiro, Seguidor e Adoção Tardia. Novamente, devem ser definidos percentuais para cada um dos métodos, observando que o total deve dar exatamente 100%.

Tamanho da Organização – Duas categorias, Pequena/Média e Grande.

Capítulo 4 – Objetivos de Governança e Gestão

No COBIT 2019, há 40 objetivos de governança e gestão. O Quadro 1 lista todos os objetivos de governança e gestão juntamente com as suas declarações de propósito.

Quadro 1 – Objetivos de Governança e Gestão

Referência	Nome	Propósito
EDM01	Implantar e manter uma estrutura de governança	Fornecer uma abordagem consistente, integrada e alinhada com a abordagem de governança corporativa. As decisões relacionadas à I&T devem ser tomadas em consonância com as estratégias e os objetivos do negócio para que o valor desejado seja realizado. Para tanto, deve ser garantido que os processos relacionados à I&T sejam supervisionados de forma efetiva e transparente; que o cumprimento dos requisitos legais, contratuais e regulatórios sejam realizados; e que os requisitos de governança para os membros do conselho sejam atendidos.
EDM02	Assegurar a entrega de benefícios	Garantir o melhor valor das iniciativas, serviços e ativos habilitados por I&T; entrega econômica de soluções e serviços. Assegurar uma imagem confiável e precisa dos custos e prováveis benefícios para que as necessidades dos negócios sejam suportadas de forma efetiva e eficiente.
EDM03	Otimização de riscos garantida	Garantir que o risco corporativo relacionado à I&T não exceda o apetite e a tolerância a risco da organização. O impacto do risco de I&T para o valor da organização é identificado e gerenciado, e o potencial de falhas de conformidade é minimizado.
EDM04	Otimização de recursos garantida	Garantir que as necessidades de recursos da organização sejam atendidas da maneira ideal, que os custos de I&T sejam otimizados e que haja um aumento da probabilidade de realização de benefícios e prontidão para mudanças futuras.
EDM05	Engajamento garantido das partes interessadas	Garantir que as partes interessadas apoiem a estratégia de I&T, que a comunicação com as partes interessadas seja eficaz e oportuna, e que a base para relatórios seja estabelecida a fim de melhorar o desempenho. Identificar áreas para melhorias e confirmar que os objetivos e estratégias de I&T estejam em consonância com a estratégia da organização.
APO01	Estrutura de gestão de TI gerenciada	Implementar uma abordagem de gestão consistente para que os requisitos de governança sejam atendidos, abrangendo componentes da governança como processos de gestão, estruturas organizacionais; papéis e responsabilidades; atividades confiáveis e repetíveis; itens de informação; políticas e procedimentos; habilidades e competências; cultura e comportamento; serviços, infraestrutura e aplicações.
APO02	Estratégia gerenciada	Apoiar a estratégia de transformação digital da organização e entregar o valor desejado através de um roteiro incremental de mudanças. Deve ser usada uma abordagem holística de I&T, garantindo que cada iniciativa esteja claramente relacionada a uma estratégia abrangente. Habilitar a mudança em todos os diferentes aspectos da organização, desde canais e processos até dados, cultura, habilidades, modelo operacional e incentivos.

APO03	Arquitetura corporativa gerenciada	Representar os diferentes blocos de construção que compõem a organização e suas inter-relações, bem como os princípios que orientam o seu desenho e a sua evolução ao longo do tempo, para permitir uma entrega padrão, responsiva e eficiente de objetivos operacionais e estratégicos.
APO04	Inovação gerenciada	Alcançar vantagem competitiva, inovação nos negócios, melhor experiência do cliente e efetividade e eficiência operacional aperfeiçoadas, ao explorar desenvolvimentos de I&T e tecnologias emergentes.
APO05	Portfólio gerenciado	Otimizar o desempenho do portfólio global de programas e projetos em resposta ao desempenho individual de programas, projetos, serviços e mudança de prioridades das demandas organizacionais.
APO06	Orçamento e custos gerenciados	Promover uma parceria entre as partes interessadas em I&T para permitir o uso efetivo e eficiente dos recursos relacionados à TI. Fornecer transparência e prestação de contas do custo e valor das soluções que habilitam negócios. Habilitar a organização a tomar decisões sobre o uso de soluções e serviços de I&T.
APO07	Recursos humanos gerenciados	Otimizar recursos humanos para atender aos objetivos corporativos.
APO08	Relacionamentos gerenciados	Viabilizar o conhecimento, habilidades e comportamentos certos para criar melhores resultados, maior confiança, confiança mútua e uso efetivo de recursos que estimulem uma relação produtiva com as partes interessadas.
APO09	Contratos de serviços gerenciados	Certificar-se de que os produtos, serviços e níveis de serviços da I&T atendam às necessidades atuais e futuras da organização.
APO10	Fornecedores gerenciados	Otimizar os recursos disponíveis de I&T para suportar a estratégia e o plano de I&T, minimizar o risco associado a fornecedores não-compromissados ou incompatíveis e garantir preços competitivos.
APO11	Qualidade gerenciada	Garantir uma entrega consistente de soluções e serviços tecnológicos para atender aos requisitos de qualidade da organização e satisfazer necessidades das partes interessadas.
APO12	Risco gerenciado	Integrar a gestão do risco organizacional relacionada à I&T com a gestão corporativa de riscos (ERM) e equilibrar os custos e benefícios da gestão corporativa do risco relacionada à I&T.
APO13	Segurança gerenciada	Manter o impacto e a ocorrência de incidentes de segurança da informação dentro dos níveis de apetite ao risco da organização.
APO14	Dados gerenciados	Garantir a utilização efetiva dos ativos de dados críticos para alcançar metas e objetivos corporativos.
BAI01	Programas gerenciados	Entender o valor desejado do negócio e reduzir o risco de atrasos inesperados, custos e erosão de valor. Para tanto, as comunicações devem ser melhoradas assim como o envolvimento da organização com os usuários finais; o valor e a qualidade das entregas devem ser garantidos, bem como o acompanhamento do programa e de projetos dentro dos programas, sendo maximizada a contribuição do programa para a carteira de investimentos.

BAI02	Requisitos definidos e gerenciados	Criar soluções ideais que atendam às necessidades da organização, minimizando riscos.
BAI03	Identificação e construção de soluções gerenciadas	Garantir a entrega ágil e escalável de produtos e serviços digitais. Devem ser estabelecidas soluções oportunas e econômicas (tecnologia, processos de negócios e fluxos de trabalho) capazes de apoiar objetivos estratégicos e operacionais corporativos.
BAI04	Disponibilidade e capacidade gerenciadas	Manter a disponibilidade de serviços, gestão eficiente de recursos e otimização do desempenho do sistema através da previsão de requisitos futuros de desempenho e capacidade.
BAI05	Mudanças organizacionais gerenciadas	Preparar e comprometer as partes interessadas para as mudanças de negócios e reduzir o risco de fracasso.
BAI06	Mudanças de TI gerenciadas	Viabilizar a entrega rápida e confiável de mudanças para os negócios. Mitigar o risco de impactar negativamente a estabilidade ou integridade do ambiente que foi mudado.
BAI07	Transição e aceitação de mudanças de TI	Implementar soluções com segurança e alinhadas com as expectativas e resultados acordados.
BAI08	Conhecimento gerenciado	Fornecer informações e conhecimento necessários para apoiar toda a equipe na governança e gestão da área de I&T e permitir a tomada de decisões baseada em informações.
BAI09	Ativos gerenciados	Controlar todos os ativos de informação e tecnologia para otimizar o valor fornecido pelo seu uso.
BAI10	Configuração gerenciada	Fornecer informações suficientes sobre os ativos do serviço para permitir que o serviço seja gerenciado efetivamente. Avaliar o impacto das mudanças e lidar com incidentes de serviço.
BAI11	Projetos gerenciados	Entregar resultados definidos no projeto e reduzir o risco de atrasos inesperados, custos e erosão de valor, com a melhora das comunicações e o envolvimento de negócios e usuários finais. Garantir o valor e a qualidade das entregas de projetos e maximizar a contribuição para os programas definidos e a carteira de investimentos.
DSS01	Operações gerenciadas	Entregar resultados operacionais de produtos e serviços de I&T como planejado.
DSS02	Solicitações e incidentes de serviço gerenciados	Alcançar o aumento da produtividade e minimizar interrupções através da resolução rápida de consultas e incidentes de usuários. Avaliar o impacto de mudanças e lidar com incidentes de serviço. Resolver as solicitações do usuário e restaurar o serviço em resposta a incidentes.
DSS03	Problemas gerenciados	Aumentar a disponibilidade, melhorar os níveis de serviço, reduzir custos, melhorar a conveniência e a satisfação do cliente por meio da redução do número de problemas operacionais e identificar as causas-raiz como parte da resolução de problemas.
DSS04	Continuidade gerenciada	Adaptar-se rapidamente, continuar as operações de negócios e manter a disponibilidade de recursos e informações em um nível aceitável para a organização em caso de interrupção significativa (por exemplo, ameaças, oportunidades, demandas).
DSS05	Serviços de segurança gerenciados	Minimizar o impacto das vulnerabilidades e incidentes de segurança da informação operacional nos negócios.

DSS06	Controles de processos de negócios gerenciados	Manter a integridade das informações e a segurança dos ativos de informação tratados dentro dos processos de negócios na organização ou em sua operação terceirizada.
MEA01	Monitoramento de desempenho e conformidade gerenciado	Proporcionar transparência no desempenho e conformidade, e impulsionar o cumprimento de metas.
MEA02	Sistema de controles internos gerenciado	Garantir transparência para as principais partes interessadas sobre a adequação do sistema de controles internos e, assim, garantir confiança nas operações, na realização de objetivos organizacionais e uma compreensão adequada do risco residual.
MEA03	Conformidade e requisitos externos gerenciados	Certificar-se de que a organização está em conformidade com todos os requisitos externos aplicáveis.
MEA04	Sistema de Avaliações Gerenciado	Permitir que a organização projete e desenvolva iniciativas de avaliações com garantia eficientes e efetivas, ao fornecer orientações sobre o planejamento, escopo, execução e acompanhamento de revisões de avaliações, por meio de um roteiro baseado em abordagens de avaliações com garantia bem aceitas.

Capítulo 5 – Gerenciamento de Desempenho no COBIT®

O gerenciamento de desempenho é uma parte essencial de um sistema de governança e gestão. "Gerenciamento de desempenho" expressa o quão bem o sistema de governança e gestão de uma organização funciona e como ele pode ser melhorado para que o nível necessário seja alcançado. Isto inclui conceitos e métodos como níveis de capacidade e níveis de maturidade. O COBIT® usa o termo "gerenciamento de desempenho no COBIT®" (COBIT® Performance Management - CPM) para descrever essas atividades, e o conceito é uma parte da estrutura do COBIT®.

Princípios do CPM

O COBIT® 2019 baseia-se nos seguintes princípios:

- O CPM deve ser simples de entender e usar;
- O CPM deve ser consistente com o modelo conceitual do COBIT® e suportá-lo;
- Deve permitir o gerenciamento de desempenho de todos os tipos de componentes do sistema de governança;
- O CPM deve fornecer resultados confiáveis, repetíveis e relevantes;
- O CPM deve ser flexível, de forma a apoiar os requisitos de diferentes organizações com diferentes prioridades e necessidades; e
- O CPM deve apoiar diferentes tipos de avaliação, desde as autoavaliações até avaliações formais ou auditorias.

Visão Geral do Gerenciamento de Desempenho no COBIT®

O modelo CPM alinha-se em parte com os conceitos do CMMI® Desenvolvimento V2.0²⁰ e os amplia:

- As atividades de processos estão associadas aos níveis de capacidade. Isso está incluído no guia *COBIT® Framework: Objetivos de Governança e Gestão*;
- Outros tipos de componentes de governança e gestão (por exemplo, estruturas organizacionais e informações) também podem ter níveis de capacidade definidos em orientações futuras; e
- Os níveis de maturidade estão associados a áreas de foco (uma coleção de objetivos de governança e gestão) e serão alcançados se todos os níveis de capacidade necessários forem obtidos.

Caso as organizações desejem continuar a usar o modelo de capacidade de processo COBIT® 5 PAM baseado na Norma ISO/IEC 15504 (agora ISO/IEC 33000), elas possuem todas as informações necessárias para fazê-lo no *COBIT® 2019 Framework: Objetivos de Governança e Gestão*. Não são necessárias publicações separadas do modelo de avaliação de processos (PAM).

Níveis de Capacidade de Processos

O COBIT® 2019 suporta um esquema de avaliação de capacidade de processo baseado no CMMI. O processo de cada objetivo de governança e gestão pode ter um nível de capacidade, variando de 0 a 5. O nível de capacidade é uma medida de quão bem um processo é implementado e está atingindo sua finalidade. A figura 7 retrata o modelo, os níveis de capacidade crescentes e as características gerais de cada um.

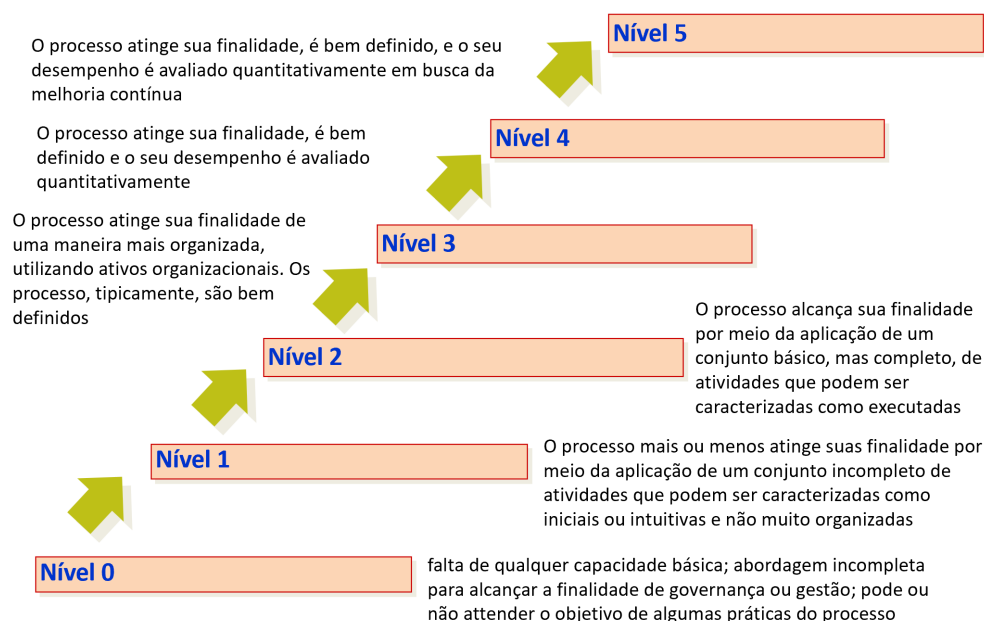


Figura 7 – Níveis de Capacidade de Processo. Adaptado de COBIT 2019 Introduction and Methodology

O núcleo do modelo COBIT® atribui níveis de capacidade a todas as atividades do processo, permitindo uma definição clara dos processos e das atividades necessárias para alcançar os diferentes níveis de capacidade.

Um nível de capacidade pode ser alcançado em diferentes graus, o que pode ser expresso por um conjunto de classificações. A gama de classificações disponíveis depende do contexto em que a avaliação de desempenho é feita:

- Alguns métodos formais que levam à certificação independente usam um conjunto binário de classificações do tipo aprovado/reprovado;
- Métodos menos formais (muitas vezes usados em contextos de melhoria de desempenho) funcionam melhor com uma gama maior de classificações, como o seguinte conjunto:
 - *Totalmente* (F) - O nível de capacidade é alcançado por mais de 85%;
 - *Em grande parte* (L) — O nível de capacidade é alcançado entre 50% e 85%;
 - *Parcialmente* (P) - O nível de capacidade é alcançado entre 15% e 50%;
 - *Nulo* (N) - O nível de capacidade é alcançado em menos de 15%.

Níveis de Maturidade de Áreas de Foco

Os níveis de maturidade estão associados a áreas de foco (ou seja, uma coleção de objetivos de governança e gestão e componentes subjacentes) e um certo nível de maturidade é alcançado se todos os processos contidos na área de foco atingirem um nível de capacidade particular.

O COBIT® 2019 define seis níveis de maturidade como medida de desempenho da área de foco, conforme mostrado na figura 8.



Figura 8 – Níveis de Maturidade de Áreas de Foco. Adaptado de COBIT 2019 Introduction and Methodology

Impacto dos Fatores de Desenho

Esta seção fornece uma visão geral do impacto potencial dos fatores de desenho em um sistema de governança para I&T organizacionais. Descreve, também, um fluxo de trabalho para desenhar um sistema de governança sob medida para a organização. Mais informações sobre esses assuntos podem ser encontradas no COBIT® 2019 Design Guide.

Os fatores de desenho impactam de diferentes maneiras a adaptação do sistema de governança de uma organização. O COBIT® 2019 distingue três tipos diferentes de impacto, ilustrados na figura 9.



Figura 9 – Impacto dos Fatores de Desenho. Adaptado de COBIT 2019 Introduction and Methodology

1. Prioridade/seleção de objetivo de gestão: o modelo central do COBIT® contém 40 objetivos de governança e gestão, cada uma consistindo num processo e uma série de componentes relacionados. Inicialmente não existe uma ordem natural de prioridade entre eles, mas, os fatores de desenho podem fazer com que alguns objetivos de governança e gestão sejam mais importantes do que outros (dependendo da organização, alguns objetivos podem se tornar insignificantes).

2. Componentes Variantes: os componentes são necessários para atingir os objetivos de governança e gestão, podendo ser influenciados ou ajustados devido a fatores de desenho.

3. Necessidade de áreas de foco específicas: exemplos de fatores de desenho que podem levar a ajustes do conteúdo do modelo principal do COBIT®, para ajustes ao contexto da organização, são: cenário de ameaças, risco específico, métodos de desenvolvimento de alvo e configuração de infraestrutura.

Estágios no Processo de Desenho

A figura 10 ilustra o fluxo para desenhar um sistema de governança sob medida.

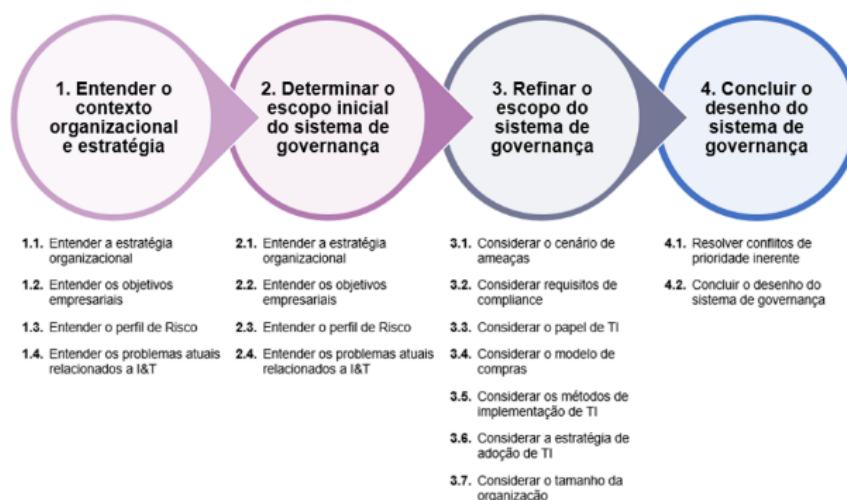


Figura 10 – Fluxo do Processo de Desenho. Adaptado de COBIT 2019 Introduction and Methodology

Os diferentes estágios do processo de desenho auxiliam na definição de recomendações para:

- priorização de objetivos de governança e gestão ou de componentes do sistema de governança;
- níveis de capacidade-alvo; ou
- adoção de variantes específicas de um componente do sistema de governança.

O primeiro estágio consiste no entendimento do contexto organizacional e da estratégia. Nesse momento, faz-se um levantamento do planejamento estratégico e de TI da organização, bem como de suas políticas e principais normativos.

No segundo estágio, começamos o desenho propriamente dito. Aqui avaliamos os quatro primeiros fatores de desenho, que determinam o escopo inicial do sistema de governança.

No terceiro estágio, são abordados os sete fatores de desenho restantes, o que se denomina de refinamento do escopo do sistema de governança.

No último estágio, busca-se a resolução de eventuais conflitos. Recomenda-se colocar todas as orientações obtidas durante as diferentes etapas em um canvas (mural) e, nesse último estágio, resolver, na medida do possível, os conflitos entre os objetivos no mural e ajustar o modelo final. Seguindo essas etapas, as organizações definirão um sistema de governança sob medida para suas necessidades.

Propósito do Guia de Implementação

O COBIT® Guia de Implementação 2019 enfatiza uma visão corporativa da governança de TI. Este guia reconhece que a TI está inserida em todas as atividades organizacionais e que não é possível separar atividades relacionadas a negócios e TI. A governança e a gestão corporativa de TI devem, portanto, ser implementadas como parte da governança corporativa, abrangendo todos os negócios, de ponta a ponta.

Uma das razões pelas quais algumas implementações de sistemas de governança falham é que elas não foram iniciadas e, em seguida, gerenciadas adequadamente como programas, para garantir que os benefícios sejam alcançados. Os programas de governança precisam ser patrocinados pela alta administração, ter seu escopo devidamente delimitado e definir objetivos que sejam realizáveis. Isso permite que a organização absorva o ritmo de mudança como foi planejado. A gestão do programa é, portanto, tratada como parte do ciclo de vida de implementação.

Abordagem de implementação do COBIT®

Existem sete fases na abordagem de implementação do COBIT®:

- Quais são os direcionadores?
- Onde estamos agora?
- Onde queremos estar?
- O que precisa ser feito?
- Como chegaremos lá?
- Chegamos lá?
- Como podemos manter o ímpeto?

A abordagem de implementação do COBIT® está resumida na figura 11.

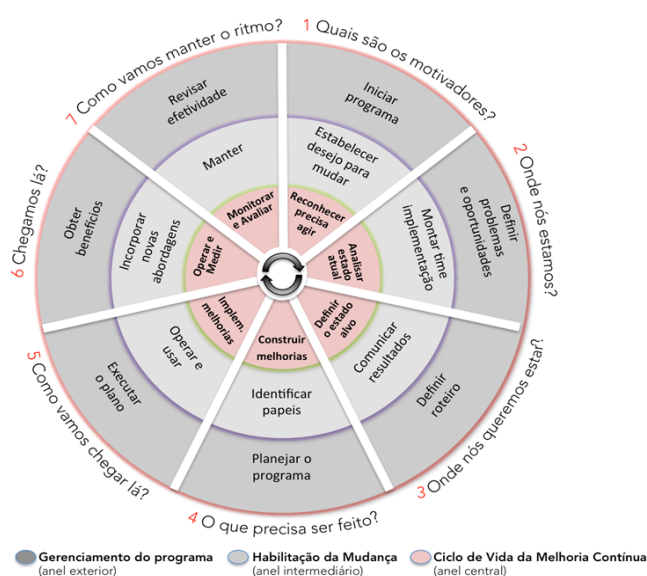


Figura 11 – Fases de Implementação do COBIT 2019. Adaptado de COBIT 2019 Introduction and Methodology

Fase 1 – Quais são os direcionadores

A fase 1 identifica os direcionadores de mudança e gera um desejo de mudança que é expresso em um esboço de um caso de negócios. Um direcionador de mudança é um evento interno ou externo, condição ou questão-chave que serve como um estímulo para a mudança. Eventos, tendências (indústria, mercado ou técnica), déficits de desempenho, implementações de software e, até mesmo, os objetivos da organização podem atuar como impulsionadores de mudança.

Preparar, manter e monitorar um caso de negócio são disciplinas fundamentais para justificar, apoiar e garantir resultados de sucesso para qualquer iniciativa, incluindo a melhoria do sistema de governança. Elas garantem um foco contínuo nos benefícios do programa e na sua realização.

Fase 2 - Onde estamos agora?

A Fase 2 alinha os objetivos relacionados à I&T com as estratégias e riscos da organização e prioriza as metas organizacionais, as metas de alinhamento e os processos mais importantes.

A partir da seleção de objetivos feitas na fase anterior, avalia-se a capacidade atual do componente processo desses objetivos.

Fase 3 – Onde queremos estar?

A fase 3 define uma meta de melhoria seguida por uma análise de lacunas para identificar soluções potenciais.

Algumas soluções serão vitórias rápidas e outras, mais desafiadoras, tarefas de médio e longo prazo. Deve ser dada prioridade a projetos que sejam mais fáceis de alcançar e que possam trazer os maiores benefícios. Tarefas de longo prazo devem ser divididas em partes gerenciáveis.

Fase 4 — O que precisa ser feito?

A fase 4 descreve como planejar soluções viáveis e práticas, ao definir projetos e um plano de mudança para implementação. Um caso de negócios bem desenvolvido pode ajudar a garantir que os benefícios do projeto sejam identificados e monitorados continuamente

Fase 5 - Como chegaremos lá?

A Fase 5 prevê a implementação das soluções propostas por meio de práticas de gestão de projetos e o estabelecimento de sistemas de monitoramento para garantir que o alinhamento com o negócio seja alcançado e o desempenho possa ser medido.

O sucesso requer conscientização e comprometimento da alta administração e o engajamento dos proprietários dos negócios e dos processos de TI.

Fase 6 - Chegamos lá?

A Fase 6 concentra-se na reavaliação da capacidade dos componentes processo dos objetivos selecionados, para verificar se as metas de melhoria estabelecidas foram

alcançadas. No caso de sucesso do projeto, é feita a transição sustentável das práticas aprimoradas de governança e gestão para as operações normais de negócios. Ele ainda se concentra em monitorar a realização das melhorias usando as métricas de desempenho e os benefícios esperados

Fase 7 – Como podemos manter o impulso?

A fase 7 analisa o sucesso geral da iniciativa, identifica outros requisitos de governança ou gestão e reforça a necessidade de melhoria contínua. Também prioriza outras oportunidades para melhoria do sistema de governança.